Decision Brief: Scaling Remote Farmer

Date: 2026-03-12 | **Audience**: Solo developer, team leads | **Phase**: Compiled

Executive Summary

Remote Farmer should scale via three parallel workstreams -- all prototyped and validated: **multi-session** (session-keyed Maps, tested [p003]), **multi-sprint** (sprints/ directory with config pointer, tested [p004]), and **repo cartography** (compiler-generated topic-map manifest in <10ms, tested [p001]). Security hardening (cookie auth, CORS restriction, Referrer-Policy) is implemented [p005], backwards compatibility is verified with 10/10 tests passing [p006], and four additional prototypes have landed since the initial brief: **compiler manifest integration** [p007], **JSON state persistence with graceful shutdown** [p008], **WebSocket transport for Cloudflare tunnel compatibility** [p009], and **CSRF protection with auth token rotation** [p010].

Stakeholder feedback [f001] flagged that config files should not duplicate git-derivable state, superseding the original config-pointer recommendations [r020, r025].

Recommendation

Continue to production integration. Nine of eleven roadmap items are now DONE. Remaining work:

1. **Named Cloudflare tunnel** -- replace quick tunnel for stable subdomain and native SSE support [r027, r036]. WebSocket fallback [p009] reduces urgency but named tunnel remains best practice.
2. **Sprint pointer resolution** -- resolve f001 conflict: determine whether sprint pointer uses config file or git-derived detection.

Total estimated remaining effort: 2--2.5 hours.

Evidence Summary

Multi-Session (13 claims, tested)

Hook payloads include stable `session_id` UUID as a natural routing key [r001]. SessionStart/SessionEnd lifecycle hooks provide explicit session boundaries [r002]. Architecture uses single server with `Map<session_id, SessionState>` and lazy

`getSession(id)` initializer [r003, r004]. Dashboard shows unified feed with session color-coding via hue-from-hash [r005, p002]. Heartbeat timeout (5min) handles crashed sessions [r007]. Estimated 2--4 hours effort [r008]. **Prototype working** -- SessionState class, session-keyed Maps, SSE tagging, pill-bar switcher all implemented [p003].

Key constraint: Lifecycle hooks are command-only, not HTTP -- requires curl wrapper [w002]. SessionStart fires on resume/clear/compact, not just new sessions [w001].

Risk: Concurrent permission requests from multiple sessions create approval confusion -- mitigated with prominent session labels + colors [r006].

Multi-Sprint (9 claims, tested)

Each sprint lives in `sprints/<slug>/` with own claims.json. Current sprint pointer in `wheat.config.json` for portability (not symlinks, which break on Windows). Dashboard shows collapsible sprint card list [r022]. Server adds `--sprints-dir` with hot-reload via `fs.watchFile` [r021]. Cross-sprint references use `sprint-slug:claim-id` format [r024]. Compiler resolves cross-sprint references without schema changes [r023]. Estimated 3--5 hours effort [r026]. **Prototype working** -- sprint scanning, `/api/sprints` endpoint, hot-reload, backwards compatible with `--claims` flag [p004].

Feedback: Config should not duplicate git-derivable state [f001] -- the active sprint can be inferred from directory scanning or git log recency rather than a config pointer. This supersedes r020 and r025.

Repo Cartography (9 claims, tested)

`wheat-manifest.json` is a topic map (not file tree) -- AI searches by concept [r017]. Auto-generated by compiler so it never drifts from source [r011]. Single `Read` call replaces 3--5 Glob/Grep calls [r012]. CLAUDE.md stays behavioral, manifest is structural [r015]. **Generator built AND wired into compiler** -- produces manifest in <10ms (~6.7ms measured), ~5.8KB, non-fatal on failure [p001, p007].

Urgency: Repo already at 157 files (not the estimated 80) [x001]. The `examples/` directory creates 62 duplicate-named files causing search noise [x002]. Context window pollution -- not I/O -- is the real cost [x003].

Risk: Manifest can mislead if out of date -- compiler-generated approach mitigates but does not eliminate [r014]. Search tools still fall back to Glob/Grep if manifest is missing [r013].

Security (14 claims, tested)

Cloudflare quick tunnels do not support SSE -- dashboard falls back to 2s polling [r027]. Quick tunnels are dev-only with 200 concurrent request limit [r028]. Token-in-URL leaks through browser history, Referer headers, proxy logs [r029]. CORS wildcard allows any website to make authenticated API calls [r030]. Full compromise on token leak: approve arbitrary tool executions, set autonomous mode, inject responses [r031]. The `/api/ask` injection vector allows attackers to respond to pending questions before the real user [r032]. Token brute force is infeasible (2^128 entropy, timingSafeEqual) but no rate limiting exists [r033]. No token rotation -- only fix for a leak is full restart [r034]. Token embedded in served HTML via template replacement [r037].

Mitigations implemented [p005]: Cookie-based auth (HttpOnly, SameSite=Strict) with 302-redirect to clean URL, CORS restricted to request origin, Referrer-Policy: no-referrer, X-Content-Type-Options: nosniff.

WebSocket transport [p009]: RFC 6455 handshake and frame encoding (~120 LOC, zero deps). Dashboard cascade fallback: WebSocket first (works through CF quick tunnels), SSE second (works local/direct), 2s polling baseline always active. 30s ping/pong heartbeat. Verified: 101 upgrade with valid token, 401 rejection on invalid.

CSRF protection + token rotation [p010]: Per-session CSRF tokens (crypto.randomBytes, 24h TTL) delivered via init payloads (SSE, WebSocket) and /api/state polling. All mutating dashboard endpoints validate X-CSRF-Token header, returning 403 on mismatch. Hook endpoints (localhost-only) exempt. Configurable auto-rotation (--token-rotation-interval) and on-demand rotation via POST /api/admin/rotate-token. Retired tokens have configurable grace period (--token-grace-period, default 60s) with timing-safe comparison. Dashboard auto-updates cookie on rotation broadcast. Zero dependencies, ~80 LOC added.

Recommended next steps: Named tunnel for SSE + OAuth [r036].

Compatibility (2 claims, tested)

Zero npm dependencies constraint maintained [d004]. **Backwards compatibility verified** -- 10-test automated suite confirms single-session workflow survives all refactors: token auth, cookie auth, /api/state, hook fallback to 'default' session, SSE stream, login page, auth rejection all working [p006].

Performance (6 claims, tested)

Manifest generator runs in <10ms [p001]. Single Read call replaces 3--5 search calls [r012]. Performance scales to 10+ sprints and 500+ claims without degrading [d005]. Current repo at

157 files makes cartography urgent [x001]. Estimated 30% context window reduction via manifest approach [r016].

State Persistence (6 claims, tested)

All server state was held in memory with zero persistence -- restart loses everything [r038]. State classifies into must-persist (trust levels, rules, activity log) vs ephemeral (pending permissions, SSE connections) [r040]. **JSON file persistence now implemented** [p008]: atomic writes (tmp+rename) to `.farmer-state.json`, restores trust levels, session rules, and activity logs on restart. Graceful shutdown via SIGTERM/SIGINT handlers denies pending permissions and flushes state. 30s periodic auto-save. ~45 LOC, zero dependencies. Verified: state survives full stop/start cycle. Event sourcing is over-engineered for this scale (<100KB state, <1/sec writes) [r042].

Tradeoffs and Risks

Risk	Severity	Evidence	Mitigation
Approval confusion with concurrent sessions [r006]	Medium	stated	Session labels + colors
Token-in-URL leakage [r029]	High	web	Cookie auth implemented [p005]
CORS wildcard [r030]	High	documented	Restricted to origin [p005]
Full compromise on token leak [r031]	High	documented	Cookie auth + Referrer-Policy [p005], token rotation done [p010]
/api/ask injection [r032]	Medium	documented	CSRF tokens implemented [p010]
SSE broken through quick tunnels [r027]	High	documented	WebSocket fallback implemented [p009]; named tunnel recommended
No token rotation [r034]	Medium	documented	On-demand + auto rotation implemented [p010]
All state in-memory [r038]	Medium	documented	JSON snapshots implemented [p008]
Manifest can mislead if stale [r014]	Low	documented	Compiler-generated, auto-updates [p007]

Config duplicates derivable state [f001]	Low	stated	Under review: git-derived sprint detection

Resolved Conflicts

f001 vs r020/r025: Stakeholder feedback argues config should not duplicate git-derivable state. The original recommendations (r020: sprints/ directory, r025: config pointer over symlinks) are superseded. Resolution pending: determine whether active sprint is inferred from fs scanning, git recency, or explicit pointer.

Implementation Roadmap

Phase	Workstream	Effort	Status
1	Manifest generator	--	DONE (p001)
2	Multi-session refactor	2-4h	DONE (p003)
3	Multi-sprint support	3-5h	DONE (p004)
4	Security hardening	--	DONE (p005)
5	Backwards compat tests	--	DONE (p006)
6	Compiler manifest integration	1h	DONE (p007)
7	State persistence	1h	DONE (p008)
8	WebSocket transport	--	DONE (p009)
9	Token rotation + CSRF	1h	DONE (p010)
10	Named tunnel / stable subdomain	2h	TODO
11	Sprint pointer resolution (f001)	0.5h	TODO

Appendix: Claim Inventory

ID	Type	Topic	Evidence	Content (abbreviated)
d001	constraint	multi-session	stated	Must support multiple concurrent sessions in dashboard

d002	constraint	multi-sprint	stated	Dashboard must support viewing/switching multiple sprints
d003	constraint	cartography	stated	Repo must be self-describing for AI models
d004	constraint	compatibility	stated	Zero npm deps, backwards compat
d005	constraint	performance	stated	AI search must be measurably faster with cartography
r001	factual	multi-session	documented	Hook payloads include stable session_id UUID
r002	factual	multi-session	documented	SessionStart/SessionEnd lifecycle hooks exist
r003	recommendation	multi-session	documented	Single-server, session-keyed Map architecture
r004	recommendation	multi-session	documented	Refactor globals to per-session state
r005	recommendation	multi-session	documented	Unified feed with session color-coding
r006	risk	multi-session	stated	Concurrent approval confusion
r007	recommendation	multi-session	documented	5min heartbeat timeout for crashed sessions
r008	estimate	multi-session	stated	2--4 hours estimated effort
r010	factual	cartography	documented	Claude Code uses Glob/Grep/Read -- no native index
r011	recommendation	cartography	documented	Auto-generate manifest via compiler
r012	factual	cartography	documented	Single Read replaces 3--5 search calls
r013	risk	cartography	documented	Search tools fall back without manifest

r014	risk	cartography	documented	Stale manifest can mislead
r015	recommendation	cartography	documented	CLAUDE.md behavioral, manifest structural
r016	estimate	performance	documented	30% context window reduction
r017	recommendation	cartography	documented	Topic map, not file tree
r020	recommendation	multi-sprint	documented	sprints/slug/ directory structure (SUPERSEDED by f001)
r021	recommendation	multi-sprint	documented	--sprints-dir with hot-reload
r022	recommendation	multi-sprint	documented	Collapsible sprint card list UI
r023	factual	multi-sprint	documented	Compiler resolves cross-sprint references
r024	factual	multi-sprint	documented	sprint-slug:claim-id reference format
r025	risk	multi-sprint	documented	Symlinks break on Windows (SUPERSEDED by f001)
r026	estimate	multi-sprint	stated	3--5 hours estimated effort
r027	factual	security	documented	CF quick tunnels don't support SSE
r028	factual	security	documented	Quick tunnels are dev-only, 200 req limit
r029	risk	security	web	Token-in-URL leaks via Referer/history/logs
r030	risk	security	documented	CORS wildcard enables cross-origin attacks
r031	risk	security	documented	Full compromise blast radius on token leak
r032	risk	security	documented	/api/ask injection via /api/decide
r033	factual	security	documented	128-bit token, no rate limiting
r034	risk	security	documented	No token rotation, restart = only fix

r035	recommendation	security	web	Cookie auth + CSRF + CORS restriction
r036	recommendation	security	web	Named tunnel or WebSocket transport
r037	risk	security	documented	Token embedded in served HTML
r038	risk	state-persistence	documented	All state in-memory, zero persistence
r039	recommendation	state-persistence	documented	JSON file snapshots, ~40 LOC
r040	factual	state-persistence	documented	State classification: must-persist vs ephemeral
r041	recommendation	state-persistence	documented	SIGTERM/SIGINT graceful shutdown handlers
r042	estimate	state-persistence	documented	Event sourcing over-engineered; JSON snapshots sufficient
w001	factual	multi-session	documented	SessionStart fires on resume/clear/compact too
w002	risk	multi-session	documented	Lifecycle hooks are command-only, not HTTP
x001	factual	performance	tested	Repo at 157 files, not 80
x002	factual	performance	tested	examples/ creates 62 duplicate-named files
x003	factual	performance	tested	Context window pollution is real cost
p001	factual	cartography	tested	Manifest generator: <10ms, ~5KB
p002	recommendation	multi-session	documented	Multi-session refactor plan
p003	factual	multi-session	tested	Multi-session prototype working
p004	factual	multi-sprint	tested	Multi-sprint prototype working
p005	factual	security	tested	Security hardening implemented

p006	factual	compatibility	tested	10/10 backwards compat tests pass
p007	factual	cartography	tested	Manifest wired into compiler, 6.7ms, non-fatal
p008	factual	state-persistence	tested	JSON persistence + graceful shutdown implemented
p009	factual	security	tested	WebSocket transport with cascade fallback
p010	factual	security	tested	CSRF protection + token rotation implemented
f001	feedback	multi-sprint	stated	Config should not duplicate git-derivable state

---

Compilation certificate: sha256:d66705c3eac8e0bfc97ea56789f9460403a4e74be07671a63069fe5f7ad81fb0 | Compiler: wheat v0.2.0 | Claims: 60 (58 active, 2 superseded) | Compiled: 2026-03-12T10:07:56.692Z